

TECHNICAL REQUIREMENTS DOCUMENT

CareFlow — Patient & Telehealth Management Platform

Document ID: TRD-MC-2026-004 | Version: 1.0 | Date: June 3, 2026 | Author: Carlos Diaz / Amir Hosseini

1. Approved Technology Stack

Layer	Technology	Rationale
Frontend Web	React 18 + TypeScript + Tailwind CSS	Team familiarity; strong accessibility tooling
Mobile	React Native 0.74 (Expo)	Code sharing with web; single JS team covers both platforms
API Gateway	Node.js 20 LTS + Express	Thin proxy/auth layer; fast response times for scheduling
Core Services	Python 3.12 + FastAPI	Scheduling engine, reminder engine -- async-first
Database	PostgreSQL 16 (AWS RDS Multi-AZ)	ACID guarantees; row-level security for PHI
Cache	Redis 7.2 (AWS ElastiCache)	Session store, slot reservation locks, rate limiting
Search / Audit	Elasticsearch 8.13	Audit log (write-once), patient search, waitlist queries
Telehealth	Twilio Programmable Video	HIPAA BAA available; WebRTC abstraction; recording API
SMS	Twilio SMS	HIPAA BAA; reliable delivery; webhook support
Email	SendGrid	Transactional email; template management
Object Storage	AWS S3 (SSE-AES256)	Recording and document storage; lifecycle policies
CDN	AWS CloudFront (US-only)	Static asset delivery; no PHI cached at edge
Infrastructure	AWS us-west-2 / us-east-1 DR	MediConnect Enterprise Agreement; data residency
IaC	Terraform 1.8 + AWS CDK	Reproducible environments; GitOps-compatible
CI/CD	GitHub Actions + AWS CodeDeploy	Automated test > staging > production pipeline
Monitoring	CloudWatch + Datadog + PagerDuty	Full-stack observability; on-call alerting
SAST	Snyk + Semgrep	Automated vulnerability scanning on every PR

2. Security Architecture

Control	Implementation
Encryption at rest	AES-256 on RDS, S3, ElastiCache (Redis AUTH + TLS)
Encryption in transit	TLS 1.3 minimum on all external and internal endpoints
Field-level encryption	Sensitive fields (SSN, insurance_id) encrypted via AWS KMS
Authentication	JWT RS256 + 15-min access tokens + rotating 8-hr refresh tokens
MFA	TOTP RFC 6238 enforced for all Provider, Admin, Compliance roles

RBAC	PostgreSQL row-level security policies enforce PHI access at DB layer
Secrets management	AWS Secrets Manager; no secrets in env vars or source code
Pen testing	Third-party OWASP-based pen test before launch (Week 26); annual thereafter
HIPAA BAAs	Executed with: AWS, Twilio, SendGrid before any PHI flows through those services

3. Performance Targets

Metric	Target
Patient portal page load (p95)	< 2 seconds at 10,000 concurrent users
API response time (p99)	< 500ms for all non-streaming endpoints
Telehealth call setup	< 3 seconds from Join click to live video
Reminder dispatch throughput	5,000 SMS + 5,000 email per minute burst
Appointment availability query	< 200ms across 47 clinics
Auto-scaling headroom	Sustains 5x average peak without manual intervention

4. Data Retention & DR

PHI retained 7 years (45 CFR s164.530). RDS: daily backups, 35-day retention, PITR to within 5 minutes. S3: lifecycle to Glacier after 90 days; delete after 7 years. DR: RDS read replica in us-east-1. RTO 4 hours, RPO 1 hour.